

Comprehensive Technical Operations & Design Report

An Evaluation of Full-Scope Offensive Penetration Testing and Enterprise Infrastructure Defenses with Splunk SIEM Architecture.

Prepared By: Kofi Okrah Agyei

Primary Target Environment: Kali Linux Attack Range vs. Ubuntu Host / Hybrid EVE-NG Range

Telemetry Stack: pfSense Core Firewall, Splunk Enterprise SIEM Platform

Classification Status: Confidential Academic Portfolio Deliverable

Reviewing System Time: September 2026

Project 1: Black Box Hacking Simulation (Capstone)

1.1 Executive Operational Framework

This operations phase involved performing an end-to-end simulated red-team cyberattack deployment against an entirely unmapped, blind **Black Box System** environment. The primary objective focused on safely discovering live nodes, intercepting internal cleartext application traffic, deploying functional exploit vectors via known CVE vulnerabilities, and compiling rigorous administrative system fixes.

1.2 Technical Execution Kill-Chain Lifecycle

- **Reconnaissance & Active Mapping:** Network discovery mappings were conducted natively via the *arp-scan* tool and aggressive network mapper deployment utilities. Active host detection isolated a live network point target mapped directly to IP block **192.168.1.186**. Service Banner grabbing routines (nmap -sV) and OS isolation runs mapped active exposures on **Port 22 (SSH)**, **Port 80 (Apache HTTP Server/WordPress Layer)**, and **Ports 139/445 (Samba SMB storage backend)**.
- **Data Ingestion & Traffic Sniffing:** Live layer-2 packet traffic captures were logged transparently via Wireshark during scan validation setups. Raw payload patterns were checked for cleartext strings and unencrypted traffic flows crossing local broadcast enclaves.
- **System Exploitation & Initial Entry:** Evaluation of exposed port infrastructures exposed unauthenticated structural write access directly on an active system network folder (share\$) via *smbclient* operations. The data leakage exposed an inner cleartext text asset named *deets.txt*, uncovering hardcoded credential patterns (togies : 12345). These credentials successfully cracked the administration portal of the WordPress framework engine (/wp-admin). Full command channel compromise was forced using Metasploit payload logic (exploit/unix/webapp/wp_admin_shell_upload), injecting a malicious authenticated PHP reverse controller shell directly into the plugin repository layout.
- **Escape & Privilege Escalation:** The dropped session landed inside a native restricted execution cage layer (rbash). This containment barrier was broken using an interactive Python internal runtime library engine switch command configuration line:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

With an open shell active, checking user capability contexts via `sudo -l` revealed an absolute global configuration error: the account retained unrestricted universal administrative wildcard operational privileges ((ALL : ALL) ALL). Issuing a rapid `sudo su` operation successfully transitioned the attack context into global system **root** clearance.

- **Flag Recovery:** Full execution control unmasked the final cryptographic verification file located at `/root/proof.txt`. Passing the raw obfuscated string assets through a custom **ROT47 Transformation cipher** program validated complete operational compromise, returning the definitive solution string:
Congratulations! Good_Luck_Ahead!

Project 2: Enterprise Hybrid Lab & Splunk SIEM Engineering

2.1 Network Topology Boundary & Zero-Trust Segmentation

This architecture project involved creating, validating, and auditing a fully virtualized production network canvas engineered inside the **EVE-NG Emulated Environment** framework. The multi-subnet logical enterprise architecture maps production server rings, DMZ zones, and remote branch locations isolated behind an industrial multi-interface **pfsense edge gateway appliance**. Enclaves were bridged securely over public transport networks using an encrypted, hardened **IPsec Site-to-Site VPN Tunnel** connection.

2.2 Automated Security Telemetry & Red Team Operations Matrix

Active validation of firewall defense rules and event logging paths was completed by running live attack chains across the secure VPN boundary tunnel: From a detached Kali node (10.1.1.10), cross-boundary discovery scans targeted the internal network layer. Lateral movement chains were leveraged by exploiting obsolete application packages on a targeted web system container node (192.168.60.131). The attacker cleanly pivoted access paths to audit highly secured backend data zones (10.3.3.10) and exploited directory traversal faults on a web server host (192.168.60.50). All telemetry was continuously consolidated via **Splunk Universal Forwarders**.

2.3 Production Detection Engineering Frameworks (Splunk SPL Queries)

To track malicious lateral traffic vectors, three custom high-fidelity detection rules were deployed in Splunk to flag threats coming over the IPsec VPN tunnel connection:

Alert Rule 1: Automated Network Enumeration & Port Scan Discovery

Isolates active reconnaissance trends by tracking high-velocity dropped connections from the remote branch space hitting host web targets inside a tight one-minute processing window.

```
index=firewall_logs sourcetype=pfsense src_ip="10.1.1.10" dest_ip="192.168.60.50"
action="blocked" OR action="rejected"
| bucket _time span=1m
| stats dc(dest_port) as unique_ports_scanned by _time, src_ip, dest_ip
| where unique_ports_scanned > 20
```

Alert Rule 2: Brute Force Credential Attacks & Password Stuffing

Monitors endpoint linux_secure streams to track system authorization breakdown metrics, identifying targeted brute force behavior directed at system nodes.

```
index=network_logs sourcetype=linux_secure src_ip="10.1.1.10" dest_ip="192.168.60.131" "Failed
password"
| stats count by src_ip, dest_ip, user
| where count > 5
```

Alert Rule 3: Web Directory Traversal & Command Injection Attempts

Scans HTTP server proxy logs (access_combined) for explicit system path indicators (e.g., etc/passwd, cmd.exe) mapped against non-standard error return blocks.

```
index=web_logs sourcetype=access_combined dest_ip="192.168.60.50" (status=404 OR status=403)
AND (uri_path="/etc/passwd" OR uri_path="/cmd.exe" OR uri_path="/bin/sh")
| table _time, src_ip, uri_path, status
```

2.4 Defensive Remediation Matrix

System Focus Component	Identified Threat Vulnerability	Strategic Structural Enterprise Fix
Samba Storage Infrastructure	Anonymous operational access parameters mapped across active directory files (share\$).	Alter the primary network daemon runtime logic within /etc/samba/smb.conf to enforce 'restrict anonymous = 2' and enforce user validation tokens.
Host System Permissions	Permissive wildcard configurations mapping unvalidated root operational rights (ALL:ALL) ALL via Sudo.	Implement strict Principle of Least Privilege policies. Audit and replace global wildcards with explicit binary execution tokens within the /etc/sudoers security map.
Web Application Layer	Outdated software version dependencies running exposed code pathways across vulnerable frameworks.	Incorporate automated configuration lifecycles. Isolate critical components inside isolated network zones protected by Web Application Firewalls (WAF).

This is for informational purposes only. For medical advice or diagnosis, consult a professional. AI responses may include mistakes.